Transilience

SECURITY ADVISORY

LexisNexis Legal & Professional AWS Cloud Breach Analysis — FulcrumSec / React2Shell (CVE-2025-55182)

Comprehensive breach advisory analyzing the FulcrumSec threat actor's exploitation of CVE-2025-55182 (React2Shell) to exfiltrate 2.04 GB of data from LexisNexis Legal & Professional's AWS cloud infrastructure, including government personnel records.

REPORT ID
`breach-20260327T120000Z-lexisnexis-fulcrumsec-react2shell`

CREATED
`2026-03-27`

THREAT ACTOR
`FulcrumSec (aka The Threat Thespians)`

CLASSIFICATION
TLP:AMBER

Executive Summary

Records Affected

3.9 Million

Database records exfiltrated from Redshift and VPC databases

Data Exfiltrated

2.04 GB

Structured data stolen from AWS cloud infrastructure

Cloud Profiles Exposed

~400,000

Including 118 .gov accounts (judges, DOJ, SEC)

Severity Rating

Critical

CVSS 10.0 — Unpatched for 82 days after CISA KEV listing

Overview

On March 3, 2026, threat actor FulcrumSec publicly claimed responsibility for breaching LexisNexis Legal & Professional's AWS cloud infrastructure by exploiting the React2Shell vulnerability (CVE-2025-55182), a critical unauthenticated remote code execution flaw with a CVSS score of 10.0. The attack, executed on February 24, 2026, leveraged an unpatched React Server Components frontend application that CISA had added to its Known Exploited Vulnerabilities catalog on December 5, 2025 — over two months prior. After gaining initial access, FulcrumSec pivoted through a misconfigured ECS task role (LawfirmsStoreECSTaskRole) with overly broad read permissions to exfiltrate 2.04 GB of structured data from Redshift data warehouses, 17 VPC databases, AWS Secrets Manager, and the Qualtrics survey platform. The stolen data includes approximately 400,000 cloud user profiles, 21,042 enterprise customer accounts, 45 employee password hashes, and sensitive records pertaining to federal judges, DOJ attorneys, and SEC staff. LexisNexis confirmed the breach on March 4, 2026, stating the compromised data was primarily legacy information from before 2020. This marks the second major data breach for LexisNexis in two years, following a December 2024 incident that affected 364,333 individuals and resulted in a class action lawsuit.

Key Findings

- **82-Day Patch Delay:** Despite CISA adding CVE-2025-55182 to its Known Exploited Vulnerabilities catalog on December 5, 2025 with a one-week remediation deadline, LexisNexis failed to patch the vulnerable React Server Components application for over 82 days, directly enabling the February 24, 2026 compromise.

- **Overprivileged ECS Task Role:** The LawfirmsStoreECSTaskRole ECS container had excessively broad read access to the production Redshift data warehouse, 17 VPC databases, AWS Secrets Manager (containing 53 plaintext secrets), and the Qualtrics survey platform — a critical violation of the principle of least privilege.
- **Government Personnel Exposure:** Among the approximately 400,000 exposed cloud user profiles, 118 accounts belonged to U.S. government personnel with .gov email addresses, including federal judges, Department of Justice attorneys, and Securities and Exchange Commission staff — raising significant national security concerns.
- **Systemic Password Hygiene Failures:** FulcrumSec highlighted severe password reuse across LexisNexis internal systems, noting that the password 'Lexis1234' appeared across at least five different AWS Secrets Manager entries, indicating systemic credential management failures.
- **Second Breach in Two Years:** This incident follows a December 2024 breach that affected 364,333 individuals and resulted in a class action lawsuit, suggesting persistent and unresolved security posture deficiencies within the organization.
- **Data Broker Extortion Model:** FulcrumSec operates a dual-platform leak site (clearnet and dark web) with a Telegram channel, seeking to sell the exfiltrated data to a single buyer rather than leak it publicly — maximizing its financial leverage and the data's black-market value.

Breach Campaign Overview

Campaign Details

Campaign Name

`FulcrumSec LexisNexis AWS Cloud Breach (Operation React2Shell)`

Timeline

Breach Window: 2026-02-24 - 2026-03-03
Public Notification: 2026-03-04

Primary Targets

- Legal Technology & Services (LexisNexis Legal & Professional)
- U.S. Federal Judiciary (federal judges with .gov accounts)
- U.S. Department of Justice (DOJ attorneys)
- U.S. Securities and Exchange Commission (SEC staff)
- Enterprise Law Firms (21,042 customer accounts)
- Academic Institutions (university clients)

Healthcare Breach Landscape

The LexisNexis breach occurs against a backdrop of escalating cloud infrastructure attacks in the legal technology and data analytics sectors. React2Shell (CVE-2025-55182), disclosed on December 3, 2025, has been rapidly weaponized by multiple threat groups including China-nexus clusters (UNC6600, Earth Lamia, Jackpot Panda) and financially motivated actors like FulcrumSec. CISA added it to the KEV catalog within 48 hours of disclosure, but many organizations — including LexisNexis — failed to patch within the recommended timeframe. The legal and regulatory data sector remains a high-value target due to the sensitivity of the data it aggregates.

2024-2025 Statistics

847
Total Incidents

312
Confirmed Disclosures

Top Breaches (2024-2025)

- **LexisNexis Legal & Professional (2026): ~400,000 profiles + 3.9M records (2026)**
- LexisNexis (December 2024 Breach): 364,333 (2024)
- Conduent Healthcare Ransomware: 25 Million (2025)
- Change Healthcare / UnitedHealth: 100 Million+ (2024)
- Snowflake Cloud Breaches (AT&T, Ticketmaster, etc.): 560 Million+ (2024)

Threat Actor Attribution

Actor Profile

Name: FulcrumSec (aka The Threat Thespians)

Attribution: First observed around September 2025. Likely financially motivated cybercriminal group with possible Canadian ties based on one attributed breach. Operates as a data extortion-only actor — does not deploy ransomware. Uses dual-platform leak sites (clearnet and Tor) and a Telegram channel for extortion. Posted the LexisNexis breach claims on BreachForums (BF) shortly after joining the platform. It remains unclear whether this is a genuinely new group or a previously known operator using a fresh alias. May purchase credentials via Initial Access Brokers (IABs).

Motivation: Financial Gain — Data extortion and single-buyer data auctioning. FulcrumSec's 'steal and squeeze' model bypasses encryption to focus exclusively on data exfiltration and public shaming to pressure victims into paying.

Attack Techniques

- Exploitation of CVE-2025-55182 (React2Shell) — unauthenticated RCE via React Server Components Flight protocol deserialization
- Abuse of overprivileged AWS ECS task role (LawfirmsStoreECSTaskRole) for lateral movement
- Exfiltration from Amazon Redshift data warehouse (536 tables)
- Exfiltration from 17 VPC databases (430+ tables)
- Harvesting plaintext secrets from AWS Secrets Manager (53 entries)
- Credential reuse exploitation across internal systems
- Public shaming via BreachForums manifesto with technical details and data samples
- Dual-platform extortion via clearnet/Tor leak sites and Telegram channel

MITRE ATT&CK Tactics

TA0001 - Initial Access (T1190: Exploit Public-Facing Application)

TA0003 - Persistence (T1078: Valid Accounts — ECS task role credentials)

TA0006 - Credential Access (T1552.001: Unsecured Credentials in Files)

TA0007 - Discovery (T1580: Cloud Infrastructure Discovery — VPC mapping)

TA0009 - Collection (T1530: Data from Cloud Storage Object)

TA0010 - Exfiltration (T1041: Exfiltration Over C2 Channel)

TA0040 - Impact (T1565: Data Manipulation — public data leak)

Technical Analysis & Indicators

Indicators of Compromise (IOCs)

Indicators of Compromise (IOCs) — LexisNexis / React2Shell

The following behavioral and exfiltration indicators are associated with the FulcrumSec breach of LexisNexis and broader React2Shell (CVE-2025-55182) exploitation campaigns observed in the wild by Google GTIG, Darktrace, Microsoft, and AWS threat intelligence teams.

Behavioral Indicators

- HTTP POST requests to React Server Components endpoints containing prototype pollution patterns combined with RSC-specific Flight protocol syntax (primary exploitation signature)
- Anomalous ECS task execution patterns — LawfirmsStoreECSTaskRole making bulk read requests to Redshift, VPC databases, and Secrets Manager outside normal operational hours
- Outbound connections from ECS containers to known malicious IPs: 172.245.5.61:38085, 5.255.121.141, 193.34.213.15 (Darktrace observed C2 endpoints)
- Creation of hidden directories ($HOME/.systemd-utils) on compromised hosts — persistence indicator for MINOCAT tunneler deployment
- Cron job and systemd service creation for persistence (associated with UNC6600 MINOCAT campaigns)
- HTTP beaconing to new or rare IP addresses with sustained SSL/HTTP traffic increases
- Bulk UNLOAD or COPY commands on Amazon Redshift tables from non-standard IAM roles
- AWS Secrets Manager GetSecretValue API calls in rapid succession from a single ECS task role
- AWS CloudTrail logs showing unusual AssumeRole activity for LawfirmsStoreECSTaskRole
- Shell-script downloads via cURL or wget from external hosts to ECS containers

Data Exfiltration Patterns

- Structured data export from 536 Redshift tables via AWS SDK or CLI UNLOAD commands
- Sequential read operations across 430+ VPC database tables within a compressed timeframe
- Extraction of 53 plaintext secrets from AWS Secrets Manager in a single session
- VPC infrastructure mapping via DescribeSubnets, DescribeSecurityGroups, and DescribeRouteTables API calls
- Qualtrics survey platform data access — 5,582 attorney survey records with respondent IP addresses
- Data staging and compression before exfiltration via HTTPS egress channels
- Total exfiltration volume: 2.04 GB of structured data over approximately 7 days (Feb 24 – Mar 3)
- FulcrumSec manifesto posted to BreachForums on March 3, 2026, with technical proof-of-access and data samples

Malware & Vulnerabilities

Malware Analysis

Family: `React2Shell Exploit (CVE-2025-55182) + Post-Exploitation Toolkit`

The primary attack vector was the React2Shell vulnerability (CVE-2025-55182), a critical unauthenticated RCE flaw in React Server Components' Flight protocol caused by insecure deserialization. CVSS 10.0. A single crafted HTTP POST request achieves arbitrary code execution on the server. While FulcrumSec primarily used standard AWS tools and SDKs for post-exploitation data access, the broader React2Shell exploitation ecosystem includes multiple malware families: MINOCAT (64-bit ELF tunneler with embedded Fast Reverse Proxy client, deployed by UNC6600), SNOWLIGHT (downloader component of VSHELL, a Go-based multi-platform backdoor, deployed by China-nexus UNC6586), HISONIC and COMPOOD backdoors, XMRIG cryptocurrency miners, Cobalt Strike beacons (generated with Cross C2), Sliver C2 framework payloads, Nezha monitoring agent, and MeshAgent remote control software. Known malicious IOC hash: SNOWLIGHT payload SHA256 7f05bad031d22c2bb4352bf0b6b9ee2ca064a4c0e11a317e6fedc694de37737a. Comprehensive IOC collections are maintained by Google Threat Intelligence, Datadog Security Labs (GitHub: DataDog/indicators-of-compromise/tree/main/react-CVE-2025-55182), and GreyNoise.

Attack Progression

1. **Vulnerability Identification**
   FulcrumSec identified an unpatched React Server Components frontend application at LexisNexis, vulnerable to CVE-2025-55182 (React2Shell). The vulnerability had been publicly disclosed on December 3, 2025, and added to CISA KEV on December 5, 2025, but remained unpatched for 82 days.

2. **Initial Access via React2Shell Exploit**
   On February 24, 2026, FulcrumSec sent a crafted HTTP POST request exploiting the Flight protocol deserialization flaw to achieve unauthenticated remote code execution on the LexisNexis React frontend server. (MITRE: T1190 — Exploit Public-Facing Application)

3. **Credential Harvesting & Privilege Escalation**
   From the compromised server, the attacker accessed the LawfirmsStoreECSTaskRole — an overprivileged ECS task role with broad read access to production infrastructure. This role provided access to Redshift, 17 VPC databases, AWS Secrets Manager, and Qualtrics. (MITRE: T1078 — Valid Accounts, T1552.001 — Unsecured Credentials)

4. **Cloud Infrastructure Discovery**
   FulcrumSec mapped the entire VPC infrastructure, identifying all accessible databases, secrets, and services. They also discovered systemic password reuse (e.g., 'Lexis1234' across five Secrets Manager entries). (MITRE: T1580 — Cloud Infrastructure Discovery)

5. **Data Exfiltration**
   Over approximately 7 days (Feb 24 – Mar 3), FulcrumSec systematically exfiltrated 2.04 GB: 536 Redshift tables, 430+ VPC database tables, 53 plaintext secrets, 3.9 million records, 21,042 customer accounts, 5,582 attorney survey records with IPs, 45 employee password hashes, and a complete VPC infrastructure map. (MITRE: T1530 — Data from Cloud Storage, T1041 — Exfiltration Over C2)

6. **Public Disclosure & Extortion**
   On March 3, 2026, FulcrumSec published a detailed manifesto on BreachForums with technical proof-of-access, data samples, and criticism of LexisNexis security practices. They simultaneously published on clearnet and Tor leak sites and promoted via Telegram, seeking a single buyer for the dataset. (MITRE: T1565 — Data Manipulation / Impact)

Compromised Data Categories

Cloud User Profiles

- Real names
- Email addresses (including 118 .gov accounts)
- Phone numbers
- Job functions and titles
- Organization affiliations

Database & Infrastructure Records

- 536 Redshift data warehouse tables
- 430+ VPC database tables
- 3.9 million total database records
- Complete VPC infrastructure map (subnets, security groups, route tables)

Survey & Support Data

- 5,582 attorney survey respondent records
- Respondent IP addresses
- Customer support tickets
- Qualtrics survey platform data

Enterprise Customer Data

- 21,042 customer account records
- Law firm client information
- Government agency account details
- University institutional records
- Products and services used per customer

Credentials & Secrets

- 53 plaintext AWS Secrets Manager entries
- 45 employee password hashes
- Systemic password reuse evidence ('Lexis1234' across 5+ entries)
- API keys and service credentials

Government Personnel Records

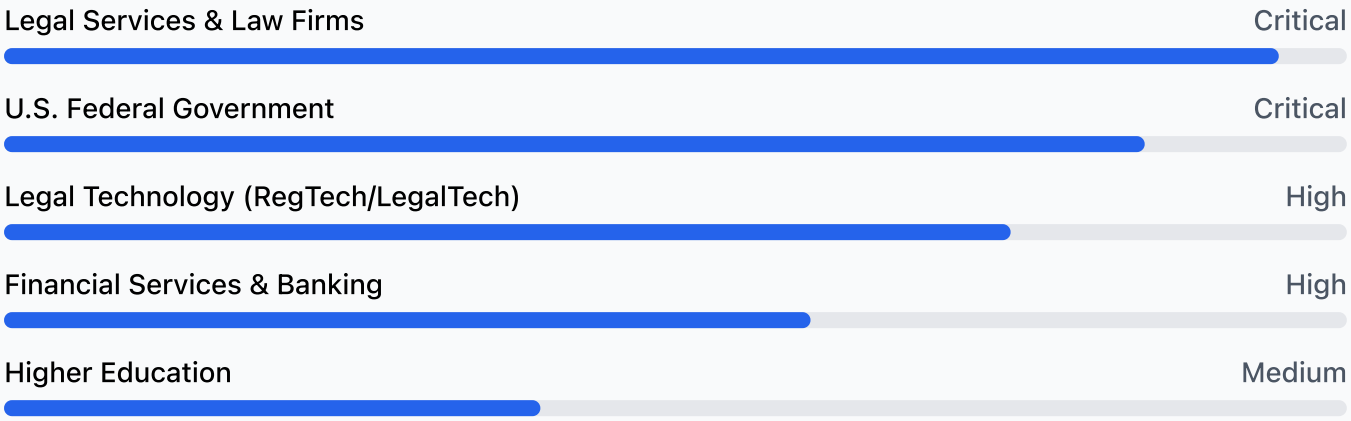
- Federal judge account profiles
- Department of Justice attorney records
- SEC staff account information
- 118 accounts with .gov email addresses

Impact Assessment & Compliance

Sectoral Impact

The LexisNexis breach has far-reaching implications across the legal, government, financial, and academic sectors. The exposure of cloud user profiles for federal judges, DOJ attorneys, and SEC staff poses direct national security risks. Enterprise law firms face client confidentiality concerns, while the broader legal technology sector confronts renewed scrutiny of cloud security practices. The breach compounds reputational damage from the 2024 incident and may accelerate regulatory action.

Impacted Sectors



Geographic Distribution

- United States (primary — all 50 states via federal judiciary and law firm clients)
- United Kingdom (RELX Group headquarters, LexisNexis parent company)
- Canada (FulcrumSec attributed ties)
- European Union (GDPR implications for any EU-resident data subjects)
- Australia, India, South Africa (LexisNexis global client base)

Regulatory Compliance

Applicable Regulations

- FISMA (Federal Information Security Modernization Act) — government personnel data on federal systems
- CISA BOD 22-01 (Binding Operational Directive) — mandatory KEV patching timeline violated
- FTC Act Section 5 — unfair or deceptive practices regarding data security representations
- State Data Breach Notification Laws (all 50 states) — notification obligations for affected individuals
- GDPR (General Data Protection Regulation) — if any EU data subjects are among the 400K profiles
- SOC 2 Type II — cloud security controls and access management requirements
- NIST Cybersecurity Framework — vulnerability management and access control standards
- ABA Model Rules of Professional Conduct — Rule 1.6 (Confidentiality) implications for law firm clients

Compliance Gaps Identified

- Failed to patch CVE-2025-55182 within CISA's recommended 7-day remediation window (82-day delay)
- Overprivileged ECS task role (LawfirmsStoreECSTaskRole) with production-wide read access violates least privilege principle
- 53 plaintext secrets stored in AWS Secrets Manager without rotation or encryption-at-rest enforcement
- Systemic password reuse ('Lexis1234') across multiple internal credential stores
- Insufficient network segmentation — single ECS role accessed Redshift, 17 VPCs, Secrets Manager, and Qualtrics
- Inadequate monitoring and alerting — 7-day exfiltration window went undetected
- No evidence of vulnerability scanning or penetration testing catching the React2Shell exposure
- Second major breach in two years suggests systemic governance and risk management failures

$4.88 Million

IBM Cost of a Data Breach Report 2024 (Professional Services sector average)

Actual costs for LexisNexis may significantly exceed this average given the government data exposure, class action liability (following the 2024 precedent), regulatory fines, forensics and remediation expenses, and reputational damage to parent company RELX Group (LSE: REL). The 2024 breach already resulted in a class action; this second incident will likely compound legal exposure.

Affected Partners

- RELX Group (parent company, LSE: REL — reputational and financial exposure)
- Enterprise Law Firms (21,042 customer accounts with case and client data)
- U.S. Federal Judiciary (federal judges' contact information exposed)
- U.S. Department of Justice (DOJ attorney records compromised)
- U.S. Securities and Exchange Commission (SEC staff data leaked)
- Qualtrics (survey platform data accessed, 5,582 attorney respondents)
- Amazon Web Services (AWS infrastructure — Redshift, ECS, Secrets Manager, VPC)
- University and Academic Institutional Clients
- Third-party forensics firm engaged for incident response

BreachForums & Dark Web Leak Activity

On March 3, 2026, FulcrumSec published a detailed manifesto on BreachForums containing technical proof-of-access, architecture diagrams, data samples, and sharp criticism of LexisNexis security practices. The post includes links to both clearnet and Tor-hosted leak sites. FulcrumSec's stated intent is to sell the full 2.04 GB dataset to a single buyer, maximizing its financial value. The group also maintains an active Telegram channel used for extortion communications and buyer solicitation. FulcrumSec explicitly stated this is a separate incident from the 2024 breach, writing: 'To be clear, this is from a breach we conducted just last week, not the 2024 breach that resulted in a massive class action.'

Active monitoring recommended on BreachForums, FulcrumSec clearnet/Tor leak sites, and their Telegram channel. Organizations in the legal, government, and financial sectors should monitor for credential stuffing attempts using the leaked data. Datadog Security Labs maintains an updated IOC repository at github.com/DataDog/indicators-of-compromise/tree/main/react-CVE-2025-55182.

Mitigation Recommendations

Strategic Recommendations Overview

The following recommendations address the immediate vulnerabilities exploited in the LexisNexis breach and provide a strategic roadmap for preventing similar incidents. Priority is given to patching the React2Shell vulnerability, enforcing least-privilege IAM policies, rotating all compromised credentials, and implementing continuous cloud security monitoring.

8
Critical & High Priority

4
Immediate Action Required

Within 30 days for critical items; 90 days for full roadmap
Implementation Target

Patch CVE-2025-55182 (React2Shell) Immediately

Critical

Apply the official React Server Components security patch to all frontend applications. Upgrade React to the latest patched version. Scan all public-facing applications for React2Shell vulnerability exposure. This should have been done within 7 days of the December 5, 2025 CISA KEV listing.

Timeline: Immediate (0-24 hours) **Effort:** Medium

Rotate All AWS Secrets and Credentials

Critical

Immediately rotate all 53 compromised AWS Secrets Manager entries, all employee passwords (especially the 45 hashed credentials), all API keys and service account tokens, and any credentials that may have been reused. Enforce unique, complex passwords and eliminate 'Lexis1234'-style credentials.

Timeline: Immediate (0-48 hours) **Effort:** High

Enforce Least-Privilege IAM Policies

Critical

Decompose the overprivileged LawfirmsStoreECSTaskRole into granular, task-specific roles. No single ECS task should have read access to Redshift, VPC databases, Secrets Manager, and external platforms simultaneously. Implement IAM Access Analyzer to detect overprivileged roles.

Timeline: Within 7 days **Effort:** High

Deploy Cloud-Native Detection and Response (CDR)

Critical

Implement real-time monitoring for anomalous AWS API activity — particularly bulk Redshift UNLOAD, Secrets Manager GetSecretValue sequences, and unusual AssumeRole patterns. Deploy AWS GuardDuty with enhanced threat intelligence feeds. The 7-day exfiltration window should have triggered automated alerts.

Timeline: Within 14 days **Effort:** High

Implement Network Segmentation and VPC Isolation

High

Segment the 17 VPC databases into isolated network zones with strict security group rules. Ensure no single role or service can traverse across all VPCs. Implement VPC Flow Logs with automated anomaly detection.

Timeline: Within 30 days **Effort:** High

Establish Continuous Vulnerability Management Program

High

Deploy automated vulnerability scanning for all public-facing applications with SLA-based patching (critical: 48 hours, high: 7 days). Integrate CISA KEV feed into the vulnerability management pipeline. The 82-day patch delay is unacceptable for a CVSS 10.0 vulnerability.

Timeline: Within 30 days **Effort:** Medium

Conduct Comprehensive Secrets Audit

High

Audit all AWS Secrets Manager entries for plaintext storage, credential reuse, and rotation compliance. Implement automated secret rotation with AWS Secrets Manager rotation policies. Deploy tools like Trufflehog or GitLeaks to scan for hardcoded credentials.

Timeline: Within 14 days **Effort:** Medium

Engage Independent Security Assessment

High

Commission a full-scope cloud security assessment and penetration test by an independent third party — covering IAM, network segmentation, vulnerability management, and incident response capabilities. Given this is the second breach in two years, an external perspective is critical.

Timeline: Within 30 days **Effort:** Medium

Implementation Roadmap

Phase 1: Immediate Containment & Remediation (Days 1-7)

- Patch all React2Shell (CVE-2025-55182) vulnerable applications
- Rotate all compromised AWS secrets, passwords, and API keys
- Revoke and replace the LawfirmsStoreECSTaskRole with least-privilege alternatives
- Enable enhanced AWS CloudTrail logging and GuardDuty threat detection
- Issue breach notification to all affected individuals per state laws
- Brief executive leadership and board on breach scope and remediation plan

Phase 2: Hardening & Detection (Weeks 2-4)

- Deploy cloud-native detection and response (CDR) tooling across all AWS accounts
- Implement IAM Access Analyzer and enforce least-privilege policies organization-wide
- Segment VPC databases into isolated network zones with strict security groups
- Establish automated vulnerability scanning with SLA-based patching
- Conduct comprehensive secrets audit and enforce rotation policies
- Deploy VPC Flow Logs with anomaly detection and automated alerting

Phase 3: Strategic Resilience (Months 2-3)

- Complete independent third-party cloud security assessment and penetration test
- Implement zero-trust architecture principles for cloud workloads
- Establish continuous dark web and threat intelligence monitoring program
- Review and update incident response playbooks based on lessons learned
- Conduct tabletop exercises simulating cloud breach scenarios
- Establish regular cadence of security reviews with RELX Group board oversight

References & Sources

BleepingComputer — LexisNexis Confirms Data Breach as Hackers Leak Stolen Files

The Register — LexisNexis Legal & Professional Confirms Data Breach (March 4, 2026)

CyberNews — Hackers Claim LexisNexis Breach Exposing 400K Users Including Federal Judges

Rescana — LexisNexis AWS Data Breach 2026: React2Shell Exploit Technical Analysis

Cybersecurity News — LexisNexis Data Breach: Threat Actor Claims 2.04 GB Stolen

CyberPress — LexisNexis Data Breach: Threat Actor Claims Theft of 2.04 GB of Data

Google Cloud Blog — Multiple Threat Actors Exploit React2Shell (CVE-2025-55182)

Microsoft Security Blog — Defending Against CVE-2025-55182 (React2Shell)

AWS Security Blog — China-Nexus Groups Rapidly Exploit React2Shell (CVE-2025-55182)

Darktrace — React2Shell: How Opportunist Attackers Exploited CVE-2025-55182 Within Hours

GreyNoise — CVE-2025-55182 Opportunistic Exploitation In The Wild

Datadog Security Labs — React2Shell IOC Repository

Joe Shenouda — New Threat Actor: FulcrumSec

American Banker — LexisNexis Hit by Second Data Breach in Two Years

Salesforce Ben — LexisNexis Data Breach: Salesforce Credentials Exposed

IDStrong — LexisNexis AWS Data Breach Exposes 400,000 Cloud User Profiles

CISA Known Exploited Vulnerabilities Catalog — CVE-2025-55182

NVD — CVE-2025-55182 Detail

Report Information

ID `breach-20260327T120000Z-lexisnexis-fulcrumsec-react2shell`

Version 1.0

Created 2026-03-27

Modified 2026-03-27

Transilience

Published 2026-03-27